MultipleKeys60KeyCalculation

clear utf8

Overly Large DNSKEY Set The attacker’s domain (example-sec.com) is signed with multiple large DNSKEY records. For instance, it can include: Multiple RSA-4096 keys, or Several elliptic-curve keys with large key sizes, or A mix of RSA/ECDSA/EdDSA algorithms for maximum complexity. Each DNSKEY RRset might be tens of kilobytes when combined (especially if multiple RRSIGs are present).

Overview

An “Overly Large DNSKEY Set” refers to a DNSSEC-signed domain whose DNSKEY Resource Record Set (RRset) is intentionally bloated. An attacker can achieve this by publishing multiple large cryptographic keys or by mixing various key algorithms that each require large signatures, resulting in a DNSKEY RRset that can reach tens (or even hundreds) of kilobytes in total size.

how many RSA 4096 keys can you fit into a 65k DNS response considering all the RRSIGs as well

To calculate how many **RSA-4096 keys** you can fit into a DNS response, we need to consider the following:

1. **Size of an RSA-4096 DNSKEY record:**
   - The public key in RSA-4096 is 512 bytes (4096 bits ÷ 8).
   - DNSKEY metadata adds approximately 25-30 bytes per record (flags, protocol, algorithm, etc.).
   - Total size per DNSKEY: ~540 bytes.
2. **Size of an RRSIG record for an RSA-4096 key:**
   - The signature size for RSA-4096 is also 512 bytes.
   - Metadata for RRSIG adds ~30-40 bytes.
   - Total size per RRSIG: ~550 bytes.

3. **Overhead of DNS response:**
    - DNS message header: 12 bytes.
    - Question section: ~20-40 bytes (depends on domain name length).
    - Additional overhead for compression, labels, etc.: ~40 bytes.
    - Total overhead: ~100 bytes.

Total size calculation per key:

- One DNSKEY + one RRSIG per key = **540 + 550 = 1090 bytes per key**.

Total DNS response size:

- Max DNS response size is 65,535 bytes.
- Subtract ~100 bytes for header and overhead.
- Available for DNSKEY and RRSIG: **65,535 - 100 = 65,435 bytes**.

Number of keys:

- Divide the available size by the per-key size:

$$\text{Keys} = \frac{65,435}{1,090} \approx 60 \text{ keys}.$$

Conclusion:

You can fit approximately **60 RSA-4096 DNSKEY records**, along with their RRSIGs, into a single 65k DNS response. This assumes no other records are included and minimal domain name length for compression efficiency.

why 60 signatures for 60 keys? Explain

2/2

You're absolutely right to question the assumption about the number of signatures relative to the number of keys. Let's clarify the relationship between DNSKEYs and RRSIGs.

Why 60 DNSKEYs can result in 60 RRSIGs:

In DNSSEC, each DNSKEY must have an **RRSIG** over the **DNSKEY RRset** to validate it. Here's how it works:

1. **DNSKEY RRset**:

- The DNSKEY RRset contains all the public keys (e.g., 60 RSA-4096 keys in this example).
- A single DNSKEY RRset is signed as a whole, not individually.

2. **RRSIG Generation**:
   - Each **DNSKEY** capable of signing (i.e., has the Secure Entry Point (SEP) flag or is a Key Signing Key (KSK)) must sign the entire DNSKEY RRset.
   - If there are **60 DNSKEYs**, each of these keys will generate its own RRSIG for the RRset.

Why the number of RRSIGs equals the number of DNSKEYs:

- Each key signs the **entire DNSKEY RRset**, not just itself.
- Thus, if you have 60 DNSKEYs in the RRset, there will be 60 RRSIGs, assuming all the keys are used to sign the RRset.

Impact on Size:

Each RRSIG is roughly the same size as an RSA-4096 key (around 550 bytes). This means that for every additional DNSKEY, you're also adding a corresponding RRSIG, doubling the effective size contribution per key (approximately 1,090 bytes per key + signature pair).

Alternative Scenarios:

- If not all DNSKEYs are used to sign the RRset (e.g., some keys are purely for encryption or backup), the number of RRSIGs might be smaller.
- However, in typical DNSSEC configurations with bloated DNSKEY sets, it's assumed all keys are used to maximize the size of the response for attack purposes.

Conclusion:

The assumption of **60 RRSIGs for 60 DNSKEYs** holds true in the context of a fully utilized DNSKEY set, where every key signs the RRset. This is common in scenarios designed to produce overly large DNS responses for abuse (e.g., DDoS amplification attacks).

Is this conversation helpful so far?